

Juice Shop

Broken Authentication

● Password Strength ★★

Log in with the administrator's user credentials without previously changing them or applying SQL Injection.

Brute Force

Tutorial

With Coding Challenge

<>





 0/4

Broken Access Control

● Admin Section ★★

Access the administration section of the application.

Good for Demos

With Coding Challenge

<>





 0/5

Broken Access Control

● View Basket ★★

View another user's shopping basket.

Tutorial

Good for Demos





 0/3



Congratulations, you solved the lab!

Share your skills!



[Continue learning >>](#)

[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: carlos

Your email is: carlos@carlos-montoya.net

Email

Update email

Congratulations, you solved the lab!

Share your skills!



[Continue learning >>](#)

[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: carlos

Your email is: carlos@carlos-montoya.net

Email

Update email

1 2 x +

Send Cancel < > Follow redirection * Burp Alt Target: https://0ad6002703546794... HTTP/2

Request		Response	
Pretty	Raw	Pretty	Raw
1	POST /forgot-password?temp-forgot-password-token=	1	HTTP/2 302 Found
2	HTTP/2	2	Location: /
3	Host: 0ad600270354679402aa256500c10014.web-security-academy.net	3	X-Frame-Options: SAMEORIGIN
4	Content-Length: 81	4	Content-Length: 0
5	Cache-Control: max-age=0	5	
6	Sec-Ch-Ua: "Not A Brand";v="99", "Chromium";v="142"	6	
7	Sec-Ch-Ua-Mobile: 0		
8	Sec-Ch-Ua-Platform: "Windows"		
9	Accept-Language: pt-BR;pt;q=0.5		
10	Origin: https://0ad600270354679402aa256500c10014.web-security-academy.net		
11	Content-Type: application/x-www-form-urlencoded		
12	Upgrade-Insecure-Requests: 1		
13	User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; AppleWebKit/537.36 (KHTML, like Gecko) Chrome/140.0.0.0 Safari/537.36		
14	Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.5,application/signed-exchange;v=b3;q=0.7		
15	Sec-Fetch-Site: same-origin		
16	Sec-Fetch-Mode: navigate		
17	Sec-Fetch-Dest: ?1		
18	Sec-Fetch-Event: document		
19	Referer: https://0ad600270354679402aa256500c10014.web-security-academy.net/forgot-password?temp-forgot-password-token=79cml2ecurtpa4dun7ac8um2o7amx9		
20	Accept-Encoding: gzip, deflate, br		
21	Priority: u=0, i		
22	temp-forgot-password-token=sustname=carlosa		
23	new-password-1=ccccnew-password-2=ccc		

Lab: Unprotected admin functionality

APPRENTICE



LAB



Solved



This lab has an unprotected admin panel.

Solve the lab by deleting the user `carlos`.



ACCESS THE LAB



Solution



Community solutions



Lab: Unprotected admin functionality with unpredictable URL

APPRENTICE



LAB



Solved



This lab has an unprotected admin panel. It's located at an unpredictable location, but the location is disclosed somewhere in the application.

Solve the lab by accessing the admin panel, and using it to delete the user

carlos.



ACCESS THE LAB



Solution



Community solutions



Lab: User role controlled by request parameter

APPRENTICE



LAB



Solved



This lab has an admin panel at `/admin`, which identifies administrators using a forgeable cookie.

Solve the lab by accessing the admin panel and using it to delete the user `carlos`.

You can log in to your own account using the following credentials:

`wiener:peter`



ACCESS THE LAB



Solution



Community solutions



Lab: User role can be modified in user profile

APPRENTICE



LAB



Solved



This lab has an admin panel at `/admin`. It's only accessible to logged-in users with a `roleid` of 2.

Solve the lab by accessing the admin panel and using it to delete the user `carlos`.

You can log in to your own account using the following credentials:

`wiener:peter`

ACCESS THE LAB

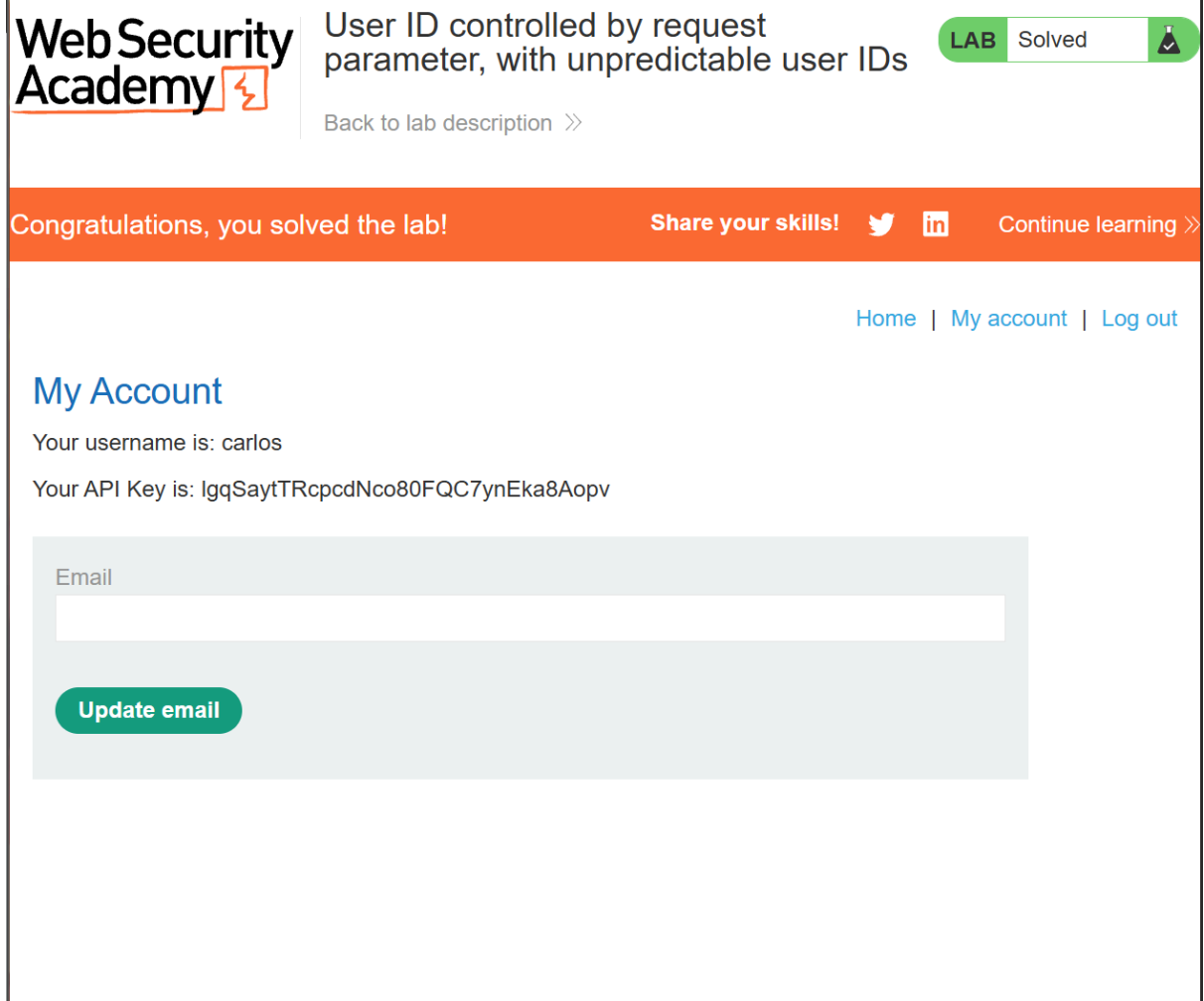
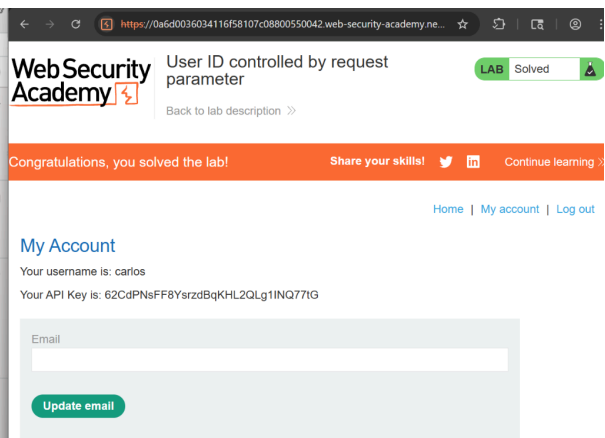
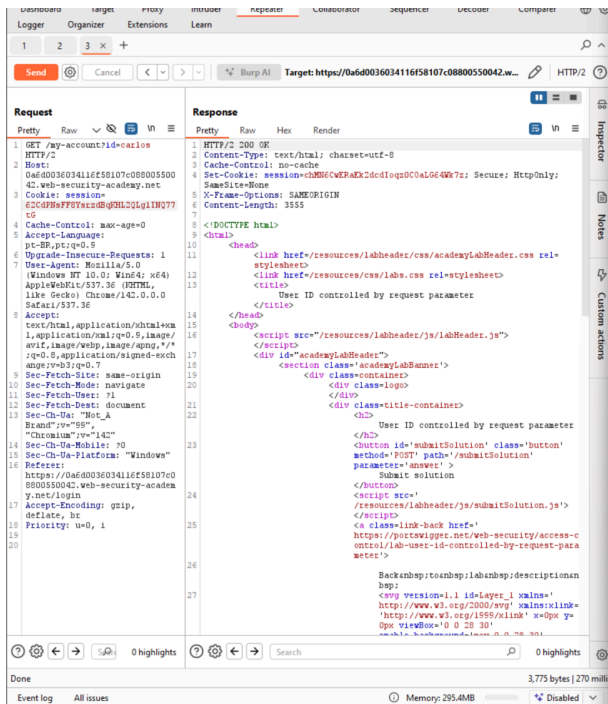


Solution



Community solutions





WebSecurity Academy

User ID controlled by request parameter with password disclosure

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills!

Continue learning >

Home | Admin panel | My account

User deleted successfully!

Users

Wiener - Delete

1. Log in using the supplied credentials and access the user account page.

2. Change the "id" parameter in the URL to administrator.

3. View the response in Burp and observe that it contains the administrator's password.

4. Log in to the administrator account and delete carlos.

Community Edition v2023.10.4 - Temporary Project

Logger Organizer Extensions Learn

MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port	Start resp
HTML		User ID controlled by r...		✓	79.125.84.16	session=FOVjnOK...	00:16:05 13 ...	8080	384
HTML		User ID controlled by r...		✓	79.125.84.16		00:16:06 13 ...	8080	395
HTML		User ID controlled by r...		✓	79.125.84.16		00:16:19 13 ...	8080	307
HTML		User ID controlled by r...		✓	79.125.84.16		00:16:21 13 ...	8080	278

Inspector

Selection 20 (0x14)

Selected text

hs81De01qxet45Iphxd2

Request attributes 2

Request query parameters 1

Request cookies 1

Request headers 18

Response headers 4

```
<form class="login-form" name="change-email-form" action="/my-account/change-email" method="POST">
  <label>
    Email
  </label>
  <input required type="email" name="email" value="">
  <input required type="hidden" name="csrf" value="395WTFZCTP4b1lgD8ma2gLD0p3YVW">
  <button class="button" type="submit">
    Update email
  </button>
</form>
<form class="login-form" action="/my-account/change-password" method="POST">
  <label>
    Password
  </label>
  <input required type="password" name="password" value="hs81De01qxet45Iphxd2">
  <input required type="password" name="password" value="hs81De01qxet45Iphxd2">
  <button class="button" type="submit">
    Update password
  </button>
</form>
```

WebSecurity Academy

User ID controlled by request parameter with data leakage in redirect

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills!

Continue learning >

Home | My account | Log out

My Account

Your username is: wiener

Your API Key is: Z4GBoyeIAPI2buHih7gCKsb8354sOIA

Email

Update email

Request

Raw

Follow redirection

Target: https://0adb00ee04d91cd1... HTTP/2

1 GET /my-account?id=carlos HTTP/2

2 Host: 0adb00ee04d91cd1cf8251653100d40

3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/142.0.0.0 Safari/537.36

4 Sec-CH-UA: "Not_A Brand";v="99", "Chromium";v="142"

5 Sec-CH-UA-Mobile: ?0

6 Sec-CH-UA-Platform: "Windows"

7 Accept-Language: pt-BR;pt;q=0.5

8 Upgrade-Insecure-Requests: 1

9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/142.0.0.0 Safari/537.36

10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

11 Sec-Fetch-Site: same-origin

12 Sec-Fetch-Mode: navigate

13 Sec-Fetch-User: ?1

14 Sec-Fetch-Dest: document

15 Referer: https://0adb00ee04d91cd1cf8251653100d40045.web-security-academy.net/

16 Accept-Encoding: gzip, deflate, br

17 Priority: u=0, i

18

19

Response

Pretty

Raw

Follow redirection

Target: https://0adb00ee04d91cd1... HTTP/2

26 https://portswigger.net/web-security/access-control/lab-user-id-controlled-by-request-parameter-with-data-leakage-in-redirect/

27 Back sp;to h p;lab sp;description sp;<div version=1.1 id=Layer_1 xmain=1 http://www.x3.org/2000/sv? xmain=xlink= http://www.w3.org/1999/xlink' x=0px y=0px viewBox=0 0 28 30 enable-background=new 0 0 28 30 xal:space= preserve title= back-arrow>

28 <polyg on points=1,4,0 0,1,2 12,6,15 0,28,8 1,4,30 15,1,15'>

29 </polyg on>

30 <polyg on points=14,3,0 12,9,1,2 25,6,15 12,9,28,8 14,3,30 28,15'>

31 </polyg on>

32 </p>

33 </div>

34 <div

35 class= s= wdg etco ntai nec- lab- stat

Inspector

Selection 32 (0x20)

Selected text

afCcdRfztcXcG79Bd95vrb3Yl0gW1g

Request attributes 2

Request query parameters 1

Request body parameters 0

Request cookies 1

Request headers 19

Response headers 5

0 highlights

0 highlights

Selection: 32 (0x20)

3,809 bytes | 372 millis

WebSecurity Academy

Insecure direct object references

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills!   Continue learning >>

Home | My account | Live chat | Log out

My Account

Your username is: carlos

Email

Update email

CONNECTED: -- Now chatting with Hal Pline --

You: Hi Hal, I think I've forgotten my password and need confirmation that I've got the right one

Hal Pline: Sure, no problem, you seem like a nice guy. Just tell me your password and I'll confirm whether it's correct or not.

You: Wow you're so nice, thanks. I've heard from other people that you can be a right ****

Hal Pline: Takes one to know one

You: OK so my password is `wY1wN44jkgYqemQ9a3X6`. Is that right?

Hal Pline: Yes it is!

You: OK thanks, bye!

Hal Pline: Do one!